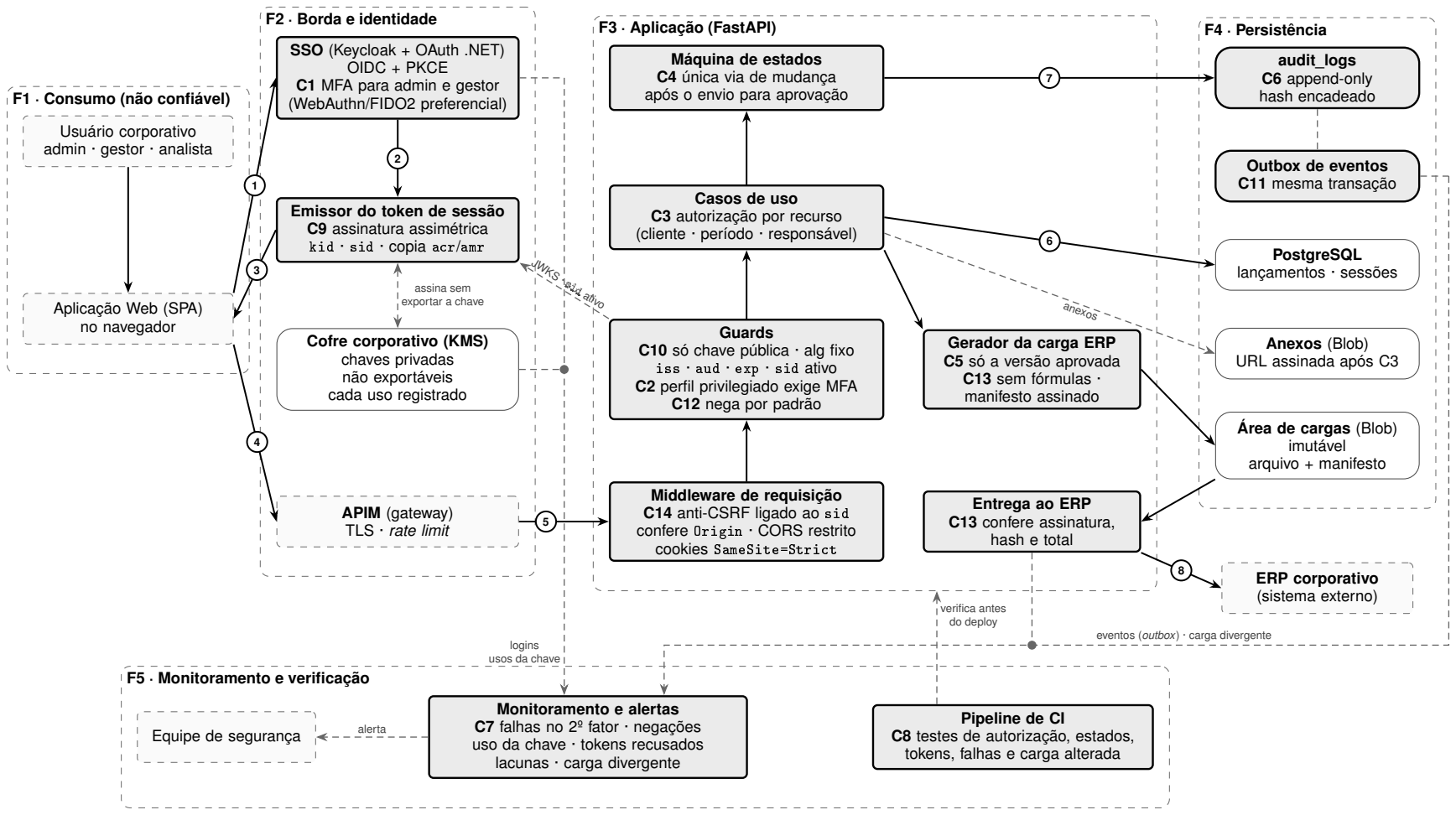
F1 · Consumo (não confiável)
Usuário corporativo
admin · gestor · analista
Aplicação Web (SPA)
no navegador
F2 · Borda e identidade
SSO (Keycloak + OAuth .NET)
OIDC + PKCE
C1 MFA para admin e gestor
(WebAuthn/FIDO2 preferencial)
Emissor do token de sessão
C9 assinatura assimétrica
kid · sid · copia acr/amr
assina sem
exportar a chave
Cofre corporativo (KMS)
chaves privadas
não exportáveis
cada uso registrado
APIM (gateway)
TLS · rate limit
JWKS + kid ativo
F3 · Aplicação (FastAPI)
Máquina de estados
C4 única via de mudança
após o envio para aprovação
Casos de uso
C3 autorização por recurso
(cliente · período · responsável)
Guards
C10 só chave pública · alg fixo
iss · aud · exp · sid ativo
C2 perfil privilegiado exige MFA
C12 nega por padrão
Middleware de requisição
C14 anti-CSRF ligado ao sid
confere Origin · CORS restrito
cookies SameSite=Strict
Gerador da carga ERP
C5 só a versão aprovada
C13 sem fórmulas ·
manifesto assinado
Entrega ao ERP
C13 confere assinatura,
hash e total
anexos
F4 · Persistência
audit_logs
C6 append-only
hash encadeado
Outbox de eventos
C11 mesma transação
PostgreSQL
lançamentos · sessões
Anexos (Blob)
URL assinada após C3
Área de cargas (Blob)
imutável
arquivo + manifesto
ERP corporativo
(sistema externo)
verifica antes
do deploy
eventos (outbox) · carga divergente
logins
usos da chave
F5 · Monitoramento e verificação
Equipe de segurança
alerta
Monitoramento e alertas
C7 falhas no 2º fator · negações
uso da chave · tokens recusados
lacunas · carga divergente
Pipeline de CI
C8 testes de autorização, estados,
tokens, falhas e carga alterada
1
2
3
4
5
6
7
8